

Daily Vulnerability Report - 2026-09-14

Window (UTC): 2026-09-14T00:00 to 2026-09-15T00:00 | Sources: NVD, CISA KEV, EPSS, Vulnrichment, GHSA, OSV | Generated 2026-09-17 09:58:47 UTC

Total	New	Updated	KEV	Critical	High	Medium	Unscored	Watchlist	Packages
1317	810	507	7	149	481	475	103	85	17

P1 - Act now (KEV / high EPSS)

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-85706 Newly scored	10.0	CRIT	Yes	0.12	gitlab:gitlab	GitLab has remediated an issue in GitLab CE/EE affecting all versions from 18.7 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that, under certain conditions, an unauthenticated user could have read arbitrary files from the GitLab server due to improper path confinement and missing authentication enforcement in the repository commits API.
CVE-2026-76461 New	9.8	CRIT	Yes	0.02	cisco:asyncos, cisco:secure_email_gateway_c195, cisco:secure_email_gateway_c395, cisco:secure_email_gateway_c695, cisco:	A vulnerability in the email parsing of Cisco AsyncOS Software for Cisco Secure Email Gateway could allow an unauthenticated, remote attacker to execute arbitrary commands with root privileges on the underlying operating system. This vulnerability is due to insufficient validation in the email parsing logic. An attacker could exploit this vulnerability by sending a crafted email message that contains malicious ...
CVE-2026-81578 Newly scored	9.8	CRIT	Yes	0.033	papercut:papercut_mf, papercut:papercut_ng	An improper access control vulnerability exists in the web management interface of PaperCut MF and PaperCut NG. Under specific conditions, unauthenticated remote requests targeting administrative functions can trigger backend actions prior to the completion of access validation checks. This allows an unauthenticated remote attacker to modify certain system configurations.
CVE-2026-82078 Newly scored	9.1	CRIT	Yes	0.036	papercut:papercut_mf, papercut:papercut_ng	An unsafe dynamic class loading vulnerability exists in the database connection utilities of PaperCut MF and PaperCut NG. The application instantiates database driver classes based on configurable driver names without validating against an allowlist of approved drivers. If an attacker can manipulate system configuration parameters, this enables the execution of arbitrary Java bytecode residing on the application c...
CVE-2026-58704 Added to KEV	8.8	HIGH	Yes	0.001	google:pixel	Google Pixel devices contain an improper authorization vulnerability in the cellular modem. A logic error may allow an attacker to bypass permission checks and escalate privileges.
CVE-2026-76460 Added to KEV			Yes		cisco:identity services engine	Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC) contain an incorrect use of privileged APIs vulnerability that could allow an unauthenticated, remote attacker to gain unauthorized access to the affected device by bypassing the web-based management interface.
CVE-2026-87886 Added to KEV			Yes		acronis:backup	Acronis Backup plugin for cPanel & WHM and extension for Plesk contains an incorrect default permissions vulnerability that could allow for privilege escalation.

P2 - High (CVSS >= 9.0 or 7.0+ with EPSS >= 0.10)

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-65381 New	10.0	CRIT		0.002	apple:macos	A validation issue existed in the entitlement verification. This issue was addressed with improved validation of the process entitlement. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. A malicious app may be able to break out of its sandbox.
CVE-2026-82434 New	10.0	CRIT		0.005		Description When ZooKeeper authentication is configured, Storm deliberately retains `storm.zookeeper.topology.auth.payload` in the topology configuration, because workers need it. Nimbus then served that configuration verbatim to any caller holding read-only topology permissions, so a user whose only grant was the ability to view a topology received its ZooKeeper credential. That credential is not read-only. The...
CVE-2026-16338 New	9.9	CRIT		0.006		IBM DataStage on Cloud Pak for Data 5.4.0.0 IBM DataStage could allow a remote authenticated attacker to perform an arbitrary file write due to improper validation of file paths.
CVE-2026-48273 Newly scored	9.9	CRIT		0.019	adobe:coldfusion	ColdFusion is affected by an Improper Neutralization of Directives in Dynamically Evaluated Code ('Eval Injection') vulnerability that could result in arbitrary code execution in the context of the current user. A low-privileged attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-82845 Newly scored	9.9	CRIT		0.004		The Masteriyo LMS WordPress plugin before 3.4.1 does not prevent user-supplied values held as metadata from being deserialized when they are read back, allowing users with a minimal account to inject arbitrary PHP objects and, by way of a class shipped in a library bundled with the Masteriyo LMS WordPress plugin before 3.4.1, write and execute arbitrary code on the server. A weaker form of the same issue is reac...
CVE-2026-89094 Newly scored	9.9	CRIT		0.005		Forgejo before 16.0.4 allows remote code execution via a crafted template repository because template expansion on files in .forgejo/template is mishandled.
CVE-2026-20353 New	9.8	CRIT		0.004		As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Email Gateway and Cisco Secure Email and Web Manager engineering team has conducted a comprehensive internal security review. This review resulted in software hardening releases that address multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-20353 are related to issues with impr...
CVE-2026-38626 Newly scored	9.8	CRIT		0.003		Garlic-Hub v1.0.1 is vulnerable to SQL Injection in src/Modules/Items/Repositories/ItemsRepository.php.
CVE-2026-52630 Newly scored	9.8	CRIT		0.005		SQL Injection vulnerability in Woltlab WCF v.6.2.4 and before allows a remote attacker to updateUserOptions in UserEditor.class.php and the update action in UserAction.class.php
CVE-2026-53952 Newly scored	9.8	CRIT		0.003		GetSimple CMS is a content management system (CMS), and GetSimple CMS CE is the community edition of that CMS. A logic flaw in GetSimple CMS (v3.4.0a and below) and GetSimpleCMS-CE (v3.3.22 and below) allows unauthenticated attackers to create a new administrator account. The application features an automated security control designed to delete the sensitive `admin/setup.php` file post-installation. However, this ...
CVE-2026-54333 New	9.8	CRIT		0.004		UEFI Firmware Parser parses BIOS, Intel ME, and UEFI firmware structures including volumes, file systems, and files. Prior to 1.14, MakeTable() in uefi_firmware/compression/Tiano/Decompress.c does not validate that bit-length values read from a crafted Tiano or EFI compressed firmware bitstream remain within the expected range from 0 through 16. The normal CompressedSection.process() to efi_compressor.TianoDecompr...
CVE-2026-54334 New	9.8	CRIT		0.004		UEFI Firmware Parser parses BIOS, Intel ME, and UEFI firmware structures including volumes, file systems, and files. Prior to 1.14, ReadCLen() in uefi_firmware/compression/Tiano/Decompress.c reads Number from GetBits(Sd, CBIT) with CBIT = 9 and can obtain 511 entries for the 510-element Sd->mCLen heap array because its loop does not enforce Index < NC. The CharC == 2 run-length path can additionally request up to ...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-55209 New	9.8	CRIT		0.004		resdata is software for reading and writing result files from the Eclipse reservoir simulator. Prior to 6.2.9, resdata insufficiently validates numeric fields, grid dimensions, keyword sizes, and array indexes while parsing untrusted GRDECL files in lib/resdata/rd_kw_grdecl.cpp and lib/resdata/rd_grid.cpp. Malformed COORD, ZCORN, CORNUM, ACTNUM, or MAPAXES data can reach rd_grid_alloc_GRDECL_kw__ with inconsisten...
CVE-2026-57123 New	9.8	CRIT		0.005		PraisonAI is a multi-agent teams system. Prior to praisonaiagents 1.6.59, ToolsMCPServer.run_sse and launch_tools_mcp_server bind to 0.0.0.0 and create /sse and /messages/ routes without invoking the available SecurityConfig authentication, origin-validation, or DNS-rebinding controls. Any reachable client can list and invoke registered tools, and a browser can target a local instance through DNS rebinding, with i...
CVE-2026-57124 New	9.8	CRIT		0.006		PraisonAI is a multi-agent teams system. Prior to 4.6.59, the default UI host applications expose POST /api/mcp/connect without mandatory authentication and accept caller-controlled command and args values that PraisonAIUI passes to StdioMCPClient to start a local process. Because the UI commands bind to 0.0.0.0 by default, a reachable unauthenticated client can execute commands as the UI service account even when...
CVE-2026-57125 New	9.8	CRIT		0.004		PraisonAI is a multi-agent teams system. Prior to praisonai 4.6.59 and praisonaiagents 1.6.59, the unauthenticated POST /api/v1/runs Jobs API accepts attacker-controlled agent_yaml, and the approve field can mark execute_command as YAML-approved before @require_approval checks critical tools. This chain allows a remote caller to cause a configured language model agent to invoke arbitrary operating-system commands ...
CVE-2026-57127 New	9.8	CRIT		0.009		PraisonAI is a multi-agent teams system. Prior to 4.6.58, recipe serve installs APIKeyAuthMiddleware or JWTAuthMiddleware when an operator selects api-key or JWT authentication, but each middleware forwards requests when PRAISONAI_API_KEY or PRAISONAI_JWT_SECRET and the corresponding recipe value are absent. Unauthenticated clients can then reach recipe execution, input, and output surfaces and may trigger connect...
CVE-2026-57131 New	9.8	CRIT		0.01		PraisonAI is a multi-agent teams system. Prior to 4.6.58, praisonai.jobs.server.create_app mounts praisonai.jobs.router.create_router under /api/v1/runs without authentication or per-job authorization. Network clients can submit attacker-controlled prompts and agent configuration, list and read jobs, stream results, and cancel or delete other jobs, exposing service credentials and connected tool capabilities to un...
CVE-2026-59178 New	9.8	CRIT		0.004	pip:esphome-device-builder fixed: 1.0.12	ESPHome Device Builder Dashboard is a dashboard for the ESPHome home management software. Prior to version 1.0.12, the dashboard reads its authentication credentials from ` \$ESPHOME_USERNAME ` and ` \$ESPHOME_PASSWORD `. Earlier versions, and the legacy ` esphome ` dashboard, read the bare ` \$USERNAME ` and ` \$PASSWORD ` instead. When the env vars were renamed the bare names were dropped with no fallback, so an operator who ...
CVE-2026-65414 New	9.8	CRIT		0.01	apple:ipados, apple:iphone_os, apple:macos, apple:visionos, apple:watchos	An out-of-bounds write issue was addressed with improved bounds checking. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. A remote attacker may be able to cause unexpected app termination or arbitrary code execution.
CVE-2026-69463 Newly scored	9.8	CRIT		0.009	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows NTFS allows an unauthorized attacker to execute code over a network.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-69525 Newly scored	9.8	CRIT		0.01	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Remote Desktop Services allows an unauthorized attacker to execute code over a network.
CVE-2026-71801 Newly scored	9.8	CRIT		0.005		An issue was discovered in s-pms SPMS-Server through v1.0. The application contains a hardcoded default access token secret within its core configuration file, which is not overridden or removed in the production environment profile. A remote, unauthenticated attacker can locally forge valid administrative session tokens to completely bypass the authentication mechanism gaining full unauthorized access to protecte...
CVE-2026-73370 New	9.8	CRIT		0.005		Incorrect Authorization vulnerability in Apache Syncope. Delegated administration security checks performed by Reconciliation service's pull and push, being incomplete, could accept calls by administrator not provided with adequate entitlements. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 Through 4.0.7, from 4.1.0-M0 through 4.1.2. Users are recommended to upgrade to ver...
CVE-2026-73470 New	9.8	CRIT		0.005		Improper Privilege Management vulnerability in Apache Syncope. Delegations can be created or updated with Roles not owned by the delegating User, or not for the same Realm subtree under the delegation management was granted for. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 Through 4.0.7, from 4.1.0-M0 through 4.1.2. Users are recommended to upgrade to version 4.0.8 / 4.1...
CVE-2026-73579 New	9.8	CRIT		0.005		Incorrect Authorization vulnerability in Apache Syncope. Any search requests are transformed into SQL, Neo4J or Elasticsearch / Opensearch queries, depending on the actual deployment configuration. An important component of such transformation is the Realms filter, which ensures that the search results are matching the requester's permissions. For non-recursive search requests it is possible that such Realms fi...
CVE-2026-73668 New	9.8	CRIT		0.005		Incorrect Authorization vulnerability in Apache Syncope. An administrator with adequate entitlements in a given Realm may be able to read via REST the full Connector configuration, confidential properties included, scoped in another Realm and thus be able to effectively duplicate such Connector instance into the Realm they have administration rights for. This issue affects Apache Syncope: from 3.0.0-M0 throu...
CVE-2026-75030 New	9.8	CRIT		0.006		Missing Authorization vulnerability in Apache Syncope. An administrator with task execution entitlements might be able to mass (de)provision group members, regardless of their group-related administration capabilities. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 Through 4.0.7, from 4.1.0-M0 through 4.1.2. Users are recommended to upgrade to version 4.0.8 / 4.1.3, which ...
CVE-2026-75171 Newly scored	9.8	CRIT		0.004		An issue in HubCore v.14.1.1 allows a remote attacker to escalate privileges via the HUBCOREID session cookie handling component.
CVE-2026-75429 Newly scored	9.8	CRIT		0.009		PowerJob versions 4.x through 5.1.2 contain an unauthenticated remote code execution vulnerability in the /friend/process endpoint of the Server-Worker transport layer
CVE-2026-75800 Newly scored	9.8	CRIT		0.004		The Frontegg SAML SSO WordPress plugin through 1.0.1 does not verify the signature or issuer of SAML authentication responses before establishing a session, allowing unauthenticated attackers to log in as any user, including administrators, as well as to create arbitrary accounts.
CVE-2026-76440 New	9.8	CRIT		0.005		As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Email Gateway and Cisco Secure Email and Web Manager engineering team has conducted a comprehensive internal security review. This review resulted in software hardening releases that address multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-76440 are related to path traversal i...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-76441 New	9.8	CRIT		0.005		As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Email Gateway and Cisco Secure Email and Web Manager engineering team has conducted a comprehensive internal security review. This review resulted in software hardening releases that address multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-76441 are related to issues with impr...
CVE-2026-76443 New	9.8	CRIT		0.004		As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Email Gateway and Cisco Secure Email and Web Manager engineering team has conducted a comprehensive internal security review. This review resulted in software hardening releases that address multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-76443 are related to issues with impr...
CVE-2026-77051 New	9.8	CRIT		0.006		Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability in Apache Syncope. An administrator with adequate entitlements can achieve execution of arbitrary SQL via stacked queries, leveraging unsanitized entityKey and opEvent parameters. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 Through 4.0.7, from 4.1.0-M0 through 4.1.2. Users a...
CVE-2026-77181 New	9.8	CRIT		0.005		Incorrect Authorization vulnerability in Apache Syncope. An administrator with ClientApp's update entitlement is unable to perform the related operation, while ClientApp's create entitlement is checked both for create and update operations on ClientApp. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 Through 4.0.7, from 4.1.0-M0 through 4.1.2. Users are recommended to upgrad...
CVE-2026-78006 Newly scored	9.8	CRIT		0.008		The The Events Calendar plugin for WordPress is vulnerable to Remote Code Execution in all versions up to, and including, 6.17.4 via the is_safe_widget_instance function. This is due to insufficient protection in is_safe_widget_instance, which can be bypassed because PHP fires magic methods during its pre-parse, combined with enable_rendering_widget_copied() forging a valid wp_hash integrity attribute before unser...
CVE-2026-78159 Newly scored	9.8	CRIT		0.008		The The Events Calendar plugin for WordPress is vulnerable to Remote Code Execution in all versions up to, and including, 6.17.3 via the parse_array function. This is due to insufficient validation of the widget 'classes' map, allowing a plain-array payload to bypass the is_safe_widget_instance() object check and reach the callable-invocation sink in Element_Classes::parse_array(). This makes it possible for unaut...
CVE-2026-78330 New	9.8	CRIT		0.006		Incorrect privilege assignment vulnerability in Apache Syncope. When the configured JWKS settings for internal JWT authentication are disclosed (at least protocol and key), an attacker can obtain admin privileges after completing a successful authentication and obtaining a valid low-privileges JWT. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 through 4.0.7, from 4.1.0-M0 throu...
CVE-2026-79396 Newly scored	9.8	CRIT		0.004		Use of hardcoded default credentials in Xiongmai IP Camera XM530 firmware HMT.CM2005-v220608.1837 and earlier stores static account credentials in unencrypted plaintext within bin/config.xml and compiled into the Sofia executable, allowing remote attackers to gain full administrative control over the camera.
CVE-2026-79577 Newly scored	9.8	CRIT		0.003		An issue in the /cas/login component of sso-master v1.0.0 allows attackers to authenticate into the application without a password via sending a crafted POST request.
CVE-2026-80351 Newly scored	9.8	CRIT		0.005	apache:camel	Improper neutralization of directives in dynamically evaluated code ('eval injection') vulnerability in Apache Camel K. An improper neutralization of directives in dynamically evaluated Maven configuration allows tenant-controlled repository content to influence code execution within the operator pod, potentially enabling tenants to execute arbitrary code with the privileges of the operator. This issue affect...
CVE-2026-80352 Newly scored	9.8	CRIT		0.004	apache:camel	Improper Control of Generation of Code ('Code Injection') vulnerability in Apache Camel K. A YAML injection vulnerability in custom resource configuration allows an authorized CR author to inject arbitrary Kubernetes objects, potentially enabling unauthorized resource creation with the privileges of the operator. This issue affects Apache Camel K: from 2.0.0 before 2.9.3, from 2.10.1 before 2.10.2. Users ...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-80976 Newly scored	9.8	CRIT		0.007		In the Linux kernel, the following vulnerability has been resolved: seg6: reset IP6CB after IPv6 decapsulation decap_and_validate() pulls the outer SRv6 headers and makes the inner packet the skb network header. The IPv6 control block still contains values collected while parsing the outer packet, including nhoff and extension-header flags. End.DX6 and End.DT6 route the inner IPv6 packet directly to the IPv6 in...
CVE-2026-81002 Newly scored	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: xdp: fix zero-copy frame layout xdp_convert_zc_to_xdp_frame() clones an XSK packet into an order-0 page and advertises PAGE_SIZE as its frame size. It allows the copied frame to occupy the page tail needed by skb_shared_info and records zero headroom even when metadata separates the frame header from packet data. An AF_XDP zero-copy packet redi...
CVE-2026-81402 Newly scored	9.8	CRIT		0.004		The DS Ad Rotator WordPress plugin through 0.8 does not perform any capability check, nonce verification, or file-type validation on its image upload handler, allowing unauthenticated attackers to upload arbitrary files, including PHP, to a web-accessible directory, which can lead to remote code execution.
CVE-2026-82232 New	9.8	CRIT		0.006		Improper neutralization of special elements used in an SQL command ('SQL injection') vulnerability in Apache Syncope. An administrator with adequate entitlements can achieve execution of arbitrary SQL via stacked queries, leveraging unsanitized sort clauses for Task search. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 through 4.0.7, from 4.1.0-M0 through 4.1.2. Users are re...
CVE-2026-82431 New	9.8	CRIT		0.005		Description `SimpleACLAuthorizer` evaluated the user-level command set by returning early when `nimbus.users` was empty, before `nimbus.groups` was considered. An operator who restricted cluster access by group alone, leaving `nimbus.users` unset, therefore received no restriction at all: every authenticated principal was permitted every user-level operation, including `submitTopology`, `beginFileUpload` and `get...
CVE-2026-82435 New	9.8	CRIT		0.006		Description The worker's Netty message decoder is installed ahead of the SASL authentication handlers in the pipeline and acts on frames before any authentication has taken place. It allocated buffers sized from a length field carried in the frame, so a single frame from an unauthenticated peer able to reach a worker slot port could drive a large allocation. `storm.messaging.netty.authentication` defaults to fal...
CVE-2026-82439 New	9.8	CRIT		0.005		Description The DRPC server kept a map from function name to request queue and created an entry the first time a function name was seen. No code path ever removed an entry: request cleanup removed the request from its queue, and the shutdown path drained queues, but the queue object and its map entry remained for the life of the process. Function names come from the client and are not constrained to functions an...
CVE-2026-84171 Newly scored	9.8	CRIT		0.004		The WP images upload on piclect WordPress plugin through 1.0 does not validate the name or type of uploaded files before writing them to a publicly accessible directory, allowing unauthenticated attackers to upload arbitrary files and execute arbitrary code on the server.
CVE-2026-84520 New	9.8	CRIT		0.001	apple:macos	A buffer overflow was addressed with improved size validation. This issue is fixed in macOS Golden Gate 27. A local attacker may be able to cause unexpected system termination or corrupt kernel memory.
CVE-2026-84561 New	9.8	CRIT		0.002	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	A double free issue was addressed with improved memory management. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. An app may be able to cause unexpected system termination or corrupt kernel memory.
CVE-2026-84609 New	9.8	CRIT		0.002		A permissions issue was addressed with improved path validation. This issue is fixed in iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. An app may be able to modify protected system files.
CVE-2026-85507 Newly scored	9.8	CRIT		0.004		ipmi-oem in FreeIPMI before 1.6.19 has a stack-based buffer overflow in _output_dell_system_info_cmc_info in ipmi-oem/ipmi-oem-dell.c (cmc-info subcommand to dell get-system-info).

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-85681 Newly scored	9.8	CRIT		0.003		The WP Component WordPress plugin through 2.2.4 does not have any capability or nonce checks on one of the actions it makes available to unauthenticated users, and it takes both the option name and the option value from the request, allowing unauthenticated attackers to overwrite any of the site's options. On a single site installation this leads to a full takeover, as registration can be enabled with a default ro...
CVE-2026-86460 New	9.8	CRIT		0.006		Cypher injection vulnerability in the Neo4j persistence layer when processing some FIQL search conditions. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 through 4.0.7, from 4.1.0-M0 through 4.1.2. Users are recommended to upgrade to version 4.0.8 / 4.1.3, which fix this issue.
CVE-2026-86793 Newly scored	9.8	CRIT		0.004		SGLang allows unauthenticated pickle deserialization through /update_weights_from_tensor when no auth keys are configured, and the SafeUnpickler policy can be bypassed because builtins.import and builtins.getattr are resolvable, enabling code execution via pickle REDUCE.
CVE-2026-87544 Newly scored	9.8	CRIT		0.003	google:chrome	Incorrect authorization in Extensions in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to bypass system access restrictions into a privileged page via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-87595 Newly scored	9.8	CRIT		0.003	google:chrome	Server-side request forgery in Mobile in Google Chrome prior to 153.0.8010.36 allowed a remote attacker leveraging social engineering to bypass system access restrictions via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-88018 Newly scored	9.8	CRIT		0.005	rclone:rclone	rclone is a command-line program to sync files and directories to and from different cloud storage providers. Prior to 1.75.1, rclone serve s3 configured with --auth-proxy but without --auth-key allows authPairMiddleware to register any client-chosen accessKeyID with an empty ws.s3Secret. gofakes3 then verifies the request's SigV4 signature against that same empty secret, while Server.auth passes the access key id...
CVE-2026-89478 Newly scored	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: sctp: drop a chunk if its transport was removed sctp_rcv() resolves the transport once per packet and leaves it in chunk->transport. The lookup reference, or the one sctp_add_backlog() takes if the socket is owned by userspace, keeps it around until the chunk has been processed. An authenticated ASCONF DEL-IP can remove it in the meantime. sctp...
CVE-2026-89479 Newly scored	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: sctp: stop processing a packet once its association is deleted sctp_endpoint_bh_rcv() looks the association up only when chunk->asoc is NULL, and caches the result in chunk->asoc and chunk->transport without taking a reference. A packet that matches no association is handed to the endpoint, so a peer can bundle COOKIE ECHO, SHUTDOWN and SHUTDOWN...
CVE-2026-89482 Newly scored	9.8	CRIT		0.007		In the Linux kernel, the following vulnerability has been resolved: nvme-tcp: do not accept C2HData based on blk_rq_payload_bytes() alone Commit 25e5cb780e62 ("nvme-tcp: fix possible crash in write_zeroes processing") established that blk_rq_payload_bytes() must not be read without first checking blk_rq_nr_phys_segments(), and recorded the result in nvme_tcp_setup_cmd_pdu() as req->data_len. The receive side was...
CVE-2026-89485 Newly scored	9.8	CRIT		0.007		In the Linux kernel, the following vulnerability has been resolved: lockd: pin next file across nlm_inspect_file lock-drop nlm_traverse_files() pins the current file with f_count++ across a mutex_unlock for nlm_inspect_file(), but nothing pins the saved next pointer. A concurrent nlm_release_file() can kfree the next file during the unlock window, and the iterator dereferences freed memory on the next loop step...
CVE-2026-89494 Newly scored	9.8	CRIT		0.007		In the Linux kernel, the following vulnerability has been resolved: ocfs2: validate lengths in dlm_mig_lockres_handler A node receiving a DLM_MIG_LOCKRES message trusts several fields of the peer-supplied dlm_migratable_lockres without validation. num_locks and lockname_len are bounded only on the sending side, and the message is never checked to actually carry num_locks migratable_lock entries. As a result dl...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89495 Newly scored	9.8	CRIT		0.007		In the Linux kernel, the following vulnerability has been resolved: ocfs2: bound namelen in dlm_migrate_request_handler Patch series "ocfs2/dlm: bound peer-controlled lengths in the o2dlm". The o2dlm receive handlers trust u8 length and count fields from the wire without bounding them, so a node in a DLM domain can corrupt or panic any other node with a malformed message. Three defects: - dlm_migrate_reques...
CVE-2026-89533 Newly scored	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: svcrdma: Fix offset arithmetic in read_chunk_range svc_rdma_read_chunk_range() walks a Read chunk's segment list to build a sub-range starting at byte offset and spanning length bytes for a Position-Zero or Call chunk. Two arithmetic defects in the per-segment loop produce wrong DMA lengths and a u32 underflow: pcl_for_each_segment(segment,...
CVE-2026-89536 Newly scored	9.8	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: SUNRPC: wait for in-flight client TLS handshake callback xs_tls_handshake_sync() gives xs_tls_handshake_done() a reference to the lower transport before submitting the handshake request. On timeout or signal, the synchronous waiter drops that reference after calling tls_handshake_cancel(). handshake_req_cancel() returns false when handshake_com...
CVE-2026-89538 Newly scored	9.8	CRIT		0.007		In the Linux kernel, the following vulnerability has been resolved: SUNRPC: Reject krb5 v2 wrap tokens with oversized ec field gss_krb5_unwrap_v2() sets buf->len to a logical length, which can be much smaller than head[0].iov_len (the allocated receive-page capacity). It then calls xdr_buf_trim() with a trim length derived from the 16-bit "extra count" (ec) field in the Kerberos v2 token header. The ec field i...
CVE-2026-89541 Newly scored	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: SUNRPC: harden gss_unwrap_resp_priv length checks gss_unwrap_resp_priv() validates the RPCSEC_GSS opaque length with offset = (u8 *) (p) - (u8 *) head->iov_base; if (offset + opaque_len > rcv_buf->len) goto unwrap_failed; maj_stat = gss_unwrap(ctx->gc_gss_ctx, offset, offset + opaque_len, rcv_buf)...
CVE-2026-89542 Newly scored	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: SUNRPC: harden gss_krb5_unwrap_v2 against short tokens gss_krb5_unwrap_v2() reads the EC and RRC header fields at ptr+4 and ptr+6 before validating that the token is at least GSS_KRB5_TOK_HDR_LEN (16) bytes long, and its rotate_left() helper passes buf->len - base to xdr_buf_subsegment() without verifying that base <= buf->len. When a caller han...
CVE-2026-89550 Newly scored	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: SUNRPC: svcauth_gss: enforce krb5 token minimum length svcauth_gss_unwrap_priv() validates only an upper bound on the wire-supplied opaque length before handing the buffer to gss_unwrap(): if (len > xdr_stream_remaining(xdr)) goto unwrap_failed; offset = xdr_stream_pos(xdr); ... maj_stat = gss_unwrap(ctx, offset, off...
CVE-2026-89551 Newly scored	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: SUNRPC: xdr_buf_trim: clamp buf->len to avoid underflow xdr_buf_trim() trims `len` bytes from the tail of an xdr_buf by walking the tail, pages, and head iovecs. Each per-section step uses min_t() so it never removes more bytes than that section holds, but the final accounting at the fix_len label subtracts the total bytes actually consumed fro...
CVE-2026-89555 Newly scored	9.8	CRIT		0.007		In the Linux kernel, the following vulnerability has been resolved: mpls: reload header after pskb_may_pull() mpls_select_multipath() calls mpls_multipath_hash() to choose a nexthop when an MPLS route has multiple nexthops. While walking the MPLS label stack, the hash routine caches hdr for the current label. After finding the bottom-of-stack label, it calls pskb_may_pull() before reading the inner IP header. ...
CVE-2026-89636 Newly scored	9.8	CRIT		0.007		In the Linux kernel, the following vulnerability has been resolved: smb: client: clear ce->tgthint in free_tgts() When free_tgts() frees all structures in ce->tlist, ce->tgthint is left pointing to one of the freed cache_dfs_tgt structures. If ce->tgthint is not reset before it is used later, it results in a use-after-free. Set ce->tgthint to NULL in free_tgts() after the elements are freed to reflect that no ...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89643 Newly scored	9.8	CRIT		0.007		In the Linux kernel, the following vulnerability has been resolved: audit: avoid dropping live tree ref on fsnotify rule autoremove audit_del_rule() is used for both netlink deletion templates and internal fsnotify autoremove. The former passes a parsed template which owns a temporary tree reference; the latter passes the installed entry itself. The unconditional audit_put_tree() at the end of audit_del_rule()...
CVE-2026-89652 Newly scored	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: ceph: bound copied dentry name length in NFS export get_name ceph_get_name() copies the MDS-supplied name into the caller's NAME_MAX-sized buffer with memcpy(name, rinfo->dname, rinfo->dname_len) and then writes name[rinfo->dname_len] = 0, without checking dname_len against NAME_MAX. A malicious or buggy MDS that returns a LOOKUPNAME reply with ...
CVE-2026-89653 Newly scored	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: ceph: reject export_targets ranks >= CEPH_MAX_MDS in mdsmmap decode MDSMap export_targets entries are monitor controlled. check_new_map() uses each entry as a bit number in a fixed stack bitmap, so a rank outside the protocol namespace can make set_bit() write past the end of the array. Reject ranks outside CEPH_MAX_MDS while decoding the map. D...
CVE-2026-89655 Newly scored	9.8	CRIT		0.007		In the Linux kernel, the following vulnerability has been resolved: ceph: fix UAF in __kick_flushing_caps() on cf entry freed during unlock list_for_each_entry() iterates ci->i_cap_flush_list but drops i_ceph_lock to send cap messages. During the unlock window, handle_cap_flush_ack() can acquire i_ceph_lock, detach cf entries with tid <= flush_tid from the list, release i_ceph_lock, and free them via ceph_free...
CVE-2026-89656 Newly scored	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: libceph: reject buckets with mismatched CRUSH ids crush_decode() stores bucket data by array slot, and the mapper later derives the per-bucket workspace index from the decoded bucket id. A malformed map can therefore make one bucket reuse another bucket's workspace by encoding an id different from -1 - slot. For uniform buckets, the second repl...
CVE-2026-89662 Newly scored	9.8	CRIT		0.007		In the Linux kernel, the following vulnerability has been resolved: NFSD: Prevent lock owner use-after-free during client teardown __destroy_client() releases a client's open owners, but a lock owner whose only reference is a blocked lock (nbl) stays on cl_ownerstr_hashtbl. client_has_state() does not count a bare owner, so DESTROY_CLIENTID can reach __destroy_client() with such owners present. __destroy_client...
CVE-2026-89669 Newly scored	9.8	CRIT		0.007		In the Linux kernel, the following vulnerability has been resolved: nfsd: initialize copy-notify stateid before publishing it nfsd4_copy_notify() finished initializing the cpntf state after nfs4_alloc_init_cpntf_state() had already linked it into the s2s_cp_stateids IDR and the parent's sc_cp_list, with cs_count == 1 (the membership reference) and none held for the caller. A racing OFFLOAD_CANCEL (crafted cl_id ...
CVE-2026-89674 Newly scored	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: nfsd: fix XDR length calculation in nfsd4_ff_encode_layoutget The XDR buffer size calculation in nfsd4_ff_encode_layoutget() has multiple errors that can result in either an out-of-bounds write or leaking uninitialized kernel memory to the client: - fh_len doesn't account for XDR padding on the file handle data - uid and gid lengths use "8 + ...
CVE-2026-89712 Newly scored	9.8	CRIT		0.007		In the Linux kernel, the following vulnerability has been resolved: NFSD: restart ssc_expire_umount walk after dropping nfsd_ssc_lock nfsd4_ssc_expire_umount() walks nn->nfsd_ssc_mount_list with list_for_each_entry_safe(ni, tmp, ...). For each expired entry it sets nsui_busy = true, drops nfsd_ssc_lock to run mntput() on the source vfsmount, then reacquires the lock to list_del + kfree the entry and continue it...
CVE-2026-90898 New	9.8	CRIT		0.003		Bifrost registers MCP clients through its management API. A stdio client is a command plus args. Bifrost starts that program in the gateway the moment the client is added. No MCP handshake required. The default is governance.auth_config.is_enabled=false. Auth off means every caller is a local admin. One unauthenticated POST /api/mcp/client is enough to run a program as the Bifrost process user (appuser on the o...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-12944 New	9.6	CRIT		0.002		IBM Langflow OSS 1.0.0 through 1.10.0 can allow attackers to execute arbitrary Python code with root privileges (UID=0) on the Langflow server by submitting components containing socket or urllib imports. This enables: (1) AWS credential theft via IMDSv1 SSRF with full IAM role permissions, (2) arbitrary file exfiltration from the container filesystem, and (3) lateral movement to internal services (PostgreSQL, Red...
CVE-2026-77005 Newly scored	9.6	CRIT		0.003		The CODE MONKEYS PROPOSALS WordPress plugin through 1.0.1 does not validate a user-supplied file path before deleting a file, and does not check the capability of the user making the request, allowing any authenticated user, such as a subscriber, to delete arbitrary files on the server, which can lead to a site takeover.
CVE-2026-77006 Newly scored	9.6	CRIT		0.002		The WebTotem Backups WordPress plugin through 1.0.1 does not validate a user-supplied file path, does not check the capability of the user making the request, and discards the result of its own CSRF check, allowing any authenticated user, such as a subscriber, to delete arbitrary files on the server, which can lead to a site takeover.
CVE-2026-86751 Newly scored	9.6	CRIT		0.003	snipeitapp:snipe-it	Snipe-IT before 8.7.0 fails to properly sanitize markdown image syntax in note fields, allowing authenticated users to read arbitrary server files and issue server-side HTTP requests. Attackers can submit markdown image syntax in checkout acceptance notes that survive HTML escaping, are expanded by CommonMark parser, and resolved by laravel-mail-auto-embed via file_get_contents or curl, exfiltrating sensitive file...
CVE-2026-21391 New	9.5	CRIT		0.004		An improper validation vulnerability exists within PingAM where a well-crafted request allows arbitrary or protected ID Token claims to be set or overridden. In certain configurations this could allow an attacker to bypass authentication controls via spoofing leading to privilege escalation or impersonation.
CVE-2026-85192 New	9.4	CRIT		0.005		Joomla Extension - regularlabs.com - Authenticated, privileged remote code execution in Conditional Content extension for Joomla < 8.0.0 - Conditional Content Pro accepts inline PHP Condition Rules in article syntax. In affected versions, the PHP is passed to the Conditions evaluator without checking who authored the article. Joomla's normal Author text filter preserves the syntax, so publishing the article causes...
CVE-2026-90680 New	9.4	CRIT		0.005		A security flaw has been discovered in D-Link DIR-823G 1.0.2B05_20181207. The impacted element is the function strcpy of the file /HNAP1/SetStaticRouteSettings of the component HNAP1. The manipulation of the argument PAddress/SubnetMask/Gateway results in stack-based buffer overflow. The attack can be launched remotely.
CVE-2026-90692 New	9.4	CRIT		0.005		A vulnerability was detected in D-Link DIR-878 120B05. This affects the function SetDynamicDNSIPv6Settings of the component Dynamic DNS IPv6 Settings. The manipulation of the argument IPv6Address/Hostname results in stack-based buffer overflow. The attack may be launched remotely.
CVE-2026-90693 New	9.4	CRIT		0.005		A flaw has been found in D-Link DIR-878 120B05. This impacts the function SetWan3Settings of the component WAN Settings. This manipulation of the argument Primary/Secondary causes stack-based buffer overflow. Remote exploitation of the attack is possible.
CVE-2026-90937 New	9.4	CRIT		0.003		froxlor versions before 2.2.5 fail to validate newline characters in subdomain redirect URLs, allowing authenticated customers to inject arbitrary nginx or Apache configuration directives. Attackers can supply URLs containing literal newlines that are written verbatim into vhost config files during cron rebuild, enabling web server configuration corruption, denial of service, or hijacking of HTTP responses across ...
GHSA-24r3-p3x6-cqvx Updated	9.4	CRIT			go:github.com/siyuan-note/siyuan/kernel	#### Duplicate Advisory This advisory has been withdrawn because it is a duplicate of GHSA-v3mg-9v85-fcm7. This link is maintained to preserve external references. #### Original Description SiYuan before v3.6.1 fails to sanitize package metadata and README content in the Bazaar marketplace, allowing malicious package authors to inject arbitrary HTML and JavaScript. Attackers can achieve remote code execution on any...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-56265 Updated	9.3	CRIT		0.026	pip:crawl4ai fixed: 0.8.7	Crawl4AI before 0.8.7 contains an authentication bypass vulnerability due to a hardcoded default JWT signing key in the Docker API server. Attackers who know the default key can forge valid authentication tokens for any user, bypassing authentication and gaining full access to protected functionality.
CVE-2026-62647 Newly scored	9.3	CRIT		0.003		A vulnerability has been identified in Reyrolle 7SR5 (All versions < V2.70). A random number generator is used to generate security-relevant values (such as session identifiers used for authentication purposes) that is not initialized with a True Random Number Generator (TRNG), resulting in a predictable sequence of generated values. This could allow an unauthenticated remote attacker to more easily predict the ge...
CVE-2026-67399 New	9.3	CRIT		0.007		Deserialization of untrusted data in WHMCS 9.0.0 before 9.0.8 and 8.0.0 before 8.13.7 allows remote attackers to execute arbitrary code.
CVE-2026-80671 Newly scored	9.3	CRIT		0.002		In the Linux kernel, the following vulnerability has been resolved: perf sched: Fix register_pid() overflow, strcpv, and BUG_ON register_pid() has several issues when processing untrusted perf.data: 1. Integer overflow: (pid + 1) * sizeof(struct task_desc *) can wrap to a small value on 32-bit systems when pid is large (e.g. 0x40000000), causing realloc to return a tiny buffer followed by out-of-bounds...
CVE-2026-85394 Newly scored	9.3	CRIT		0.002		python-jose through 3.5.0 fails to properly validate asymmetric keys in HMAC initialization, accepting DER-encoded public keys that lack PEM armor or SSH prefixes. Attackers holding the service's public key can forge HS256 tokens that pass verification when algorithms are not explicitly restricted. This is an incomplete fix for CVE-2024-33663.
CVE-2026-85428 Newly scored	9.3	CRIT		0.005		MOOS core-moos through 10.4.0 contains an authentication bypass vulnerability in the optional MOOSDB HTTP server that allows unauthenticated clients to write variables. Attackers can send HTTP requests with variable names and values to the MOOSDB HTTP server port to modify MOOS variables including actuator and override commands without authentication.
CVE-2026-85433 Newly scored	9.3	CRIT		0.003		MOOS essential-moos pShare through 10.0.1 fails to properly authorize PSHARE_CMD messages, allowing any publisher to reconfigure network routes and listeners at runtime. Attackers can send crafted PSHARE_CMD messages with cmd=output or cmd=input parameters to open new listeners on arbitrary addresses and redirect or duplicate bus traffic to attacker-controlled destinations.
CVE-2026-85438 Newly scored	9.3	CRIT		0.005		MOOS-IvP through 24.8.1 contains a buffer overflow vulnerability in StringToIvPFunction() where dimension, piece, and degree counts from encoded BHV_IPF payloads are used as allocation sizes and loop bounds without validation. Attackers can supply crafted payloads with mismatched dimension values to write attacker-controlled doubles past the end of the IvPBox weight array, causing memory corruption and potential c...
CVE-2026-85661 Newly scored	9.3	CRIT		0.004		excel-mcp-server 0.1.8 fails to enforce path confinement in stdio mode when EXCEL_FILES_PATH is unset, allowing attackers to read and write arbitrary files. Attackers can supply unchecked file paths to read and write tools to access any file accessible to the process.
CVE-2026-85688 Newly scored	9.3	CRIT		0.004		TEN Framework 0.11.71 contains unauthenticated arbitrary file read and write vulnerabilities in the TMAN Designer file-content API endpoints. Attackers can submit POST and PUT requests to the /api/designer/v1/file-content endpoints to read arbitrary files or write malicious content to system paths, enabling code execution through authorized_keys, cron files, or executable graph files.
CVE-2026-86543 Newly scored	9.3	CRIT		0.004		knowns versions before 0.30.0 serve the management API without authentication on all network interfaces by default, with no password required on fresh installations. Attackers can access the unauthenticated /api/tunnel/start endpoint to provision a public tunnel and republish the API at a publicly accessible address.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-87929 Newly scored	9.3	CRIT		0.003		MaxSite CMS through 109.6 ships with a hardcoded session encryption key in application/config/config.php that is never changed during installation, allowing unauthenticated attackers to forge administrator session cookies. Attackers can mint a malicious ci_session cookie with administrator privileges by computing an HMAC-SHA1 using the publicly known encryption key, bypassing authentication checks in is_login() an...
CVE-2026-88877 Newly scored	9.3	CRIT		0.004	traefik:traefik	Traefik is a HTTP reverse proxy and load balancer. In versions >= v3.7.0 and <= v3.7.11, the Kubernetes ingress-nginx provider mishandles Ingresses that carry both an authentication annotation and the nginx.ingress.kubernetes.io/from-to-www-redirect annotation. For such Ingresses the provider creates an additional 'sibling' router that matches on the host alone, carries only the RedirectRegex middleware, and still...
CVE-2026-89448 Newly scored	9.3	CRIT		0.001		In the Linux kernel, the following vulnerability has been resolved: iommu/vt-d: Force requesting ACS when tboot is enabled Currently the conditions of requesting ACS in detect_intel_iommu() don't include tboot, leading to a possible misconfiguration with ACS disabled (e.g. due to user opts) while iommu is later forced on by tboot_force_iommu(). Fix it by checking tboot in detect_intel_iommu().
CVE-2026-90558 Newly scored	9.3	CRIT		0.005		sngrep through 1.8.4 contains stack buffer overflow vulnerabilities in SIP attribute formatting routines when header values exceed the 255-byte buffer limit. Attackers can craft malicious SIP packets with oversized Call-ID, X-Call-ID, or other header fields to overflow stack buffers and cause crashes or execute arbitrary code during packet parsing and rendering.
CVE-2026-90919 New	9.3	CRIT		0.01		LightLLM through 1.2.0 contains a remote code execution vulnerability in the Config Server's unauthenticated /visual_register WebSocket endpoint that passes the first client frame directly to pickle.loads(). Attackers can reach the Config Server port and send a malicious serialized payload with a __reduce__ method to execute arbitrary code with Config Server process privileges.
CVE-2026-90942 New	9.3	CRIT		0.002		Casdoor through 4.4.0 fails to properly mask the instance-wide built-in certificate private key in /api/get-certs and /api/get-cert endpoints, allowing organization administrators to retrieve it. Attackers can use the exposed private key to forge JWT tokens for any user in any organization, including global administrators.
CVE-2026-90943 New	9.3	CRIT		0.002		parallax filament-comments through 3.0.0 contains a stored cross-site scripting vulnerability in comment body rendering that allows authenticated panel users to inject malicious scripts. Attackers can store XSS payloads in comment bodies that execute in the browsers of other users viewing those comments, including administrators, enabling session token theft and unauthorized actions.
CVE-2026-90945 New	9.3	CRIT		0.005		Crawlab through 0.6.3 uses a hard-coded HMAC-SHA256 secret for JWT token signing that cannot be overridden via configuration or environment variables. Unauthenticated attackers can forge valid administrator tokens to access administrative APIs and execute code on worker nodes.
CVE-2026-90961 New	9.3	CRIT		0.005		The LdapAuth and LinOTPAuth authentication plugins in MISP contain an authentication bypass vulnerability. Both LdapAuthenticate and LinOTPAAuthenticate replace CakePHP's FormAuthenticate class but fail to replicate its _checkFields() input validation guard. As a result, the email and password fields extracted from the login request are passed to downstream authentication logic without verifying that they are non-e...
GHSA-5w6g-rc45-wvv9 Updated	9.3	CRIT			npm:flowise fixed: 2.1.4	#### Duplicate Advisory This advisory has been withdrawn because it is a duplicate of GHSA-5cph-wvm9-45gj. This link is maintained to preserve external references. #### Original Description Flowise before 2.1.4 allows configuration to be injected into the Chainflow during execution via the overrideConfig option, supported in both the frontend web integration and the backend Prediction API. Because this feature is e...
CVE-2026-12258 New	9.2	CRIT		0.004		Inadequate access control in Hiperdino's REST v1.0 API. The public endpoint 'customer/check' could allow an authenticated attacker to enter a telephone number or an email address. When the value entered belongs to a registered customer, the service returns the associated information (email address and telephone number). No authentication is required beyond a static bearer token, and there is no rate limiting or ge...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-57578 New	9.2	CRIT		0.004		DotVVM is an open source MVVM framework for web applications. Prior to 4.2.11, 4.3.15, and 5.0.0-preview09-final, AuthorizeActionFilter performs no authorization because its explicit ICommandActionFilter.OnCommandExecutingAsync, IViewModelActionFilter.OnViewModelCreatedAsync, and IPresenterActionFilter.OnPresenterExecutingAsync implementations return completed tasks instead of invoking the corresponding checks. Ap...
CVE-2026-85620 Newly scored	9.2	CRIT		0.004		Postgres MCP Pro 0.3.0 contains a restricted-mode bypass vulnerability where function-name validation is not applied to RangeFunction nodes in FROM clauses. Attackers can execute file-reading functions like pg_read_file through FROM-clause syntax to read arbitrary files despite restricted-mode protections.
CVE-2026-85625 Newly scored	9.2	CRIT		0.005		sift (sift.js) 17.1.3 enumerates query keys with for...in, which walks the object prototype chain, and dispatches any matched operator key including \$where. The \$where operation compiles a string value into a function using new Function unless CSP_ENABLED is set (not set by default). As a result, if a prototype-pollution primitive elsewhere in the process sets Object.prototype.\$where to a malicious string, even be...
CVE-2026-90456 Newly scored	9.2	CRIT		0.003		An example environment-configuration file for a bundled inventory-management component ships with a fixed, publicly-known administrative password. A deployment that copies this example file into active configuration without running the setup routine that regenerates credentials will expose that component's administrative interface to anyone aware of the default value.
CVE-2026-43790 New	9.1	CRIT		0.003	apple:macos	The issue was addressed with improved memory handling. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. A remote attacker may be able to cause unexpected system termination or corrupt kernel memory.
CVE-2026-50006 New	9.1	CRIT		0.008		Anyquery is an SQL query engine built on top of SQLite. Prior to 0.4.5, anyquery server forwards unauthenticated SQL from its MySQL-compatible server port to SQLite without restricting ATTACH DATABASE filesystem targets. A remote attacker can select any path writable by the Anyquery server process, cause SQLite to create a database file there, and place attacker-controlled table content in that file. This permits ...
CVE-2026-53713 New	9.1	CRIT		0.004		Envoy Gateway is an open source project for managing Envoy Proxy as a standalone or Kubernetes-based application gateway. Prior to 1.7.4 and 1.8.1, to_absolute_normalized_path in internal/gatewayapi/luavalidator/security.lua does not collapse redundant separators before is_critical_path evaluates Lua submitted through EnvoyExtensionPolicy during default Strict validation. Linux resolves a double-slash absolute pat...
CVE-2026-57145 New	9.1	CRIT		0.004		PraisonAI is a multi-agent teams system. Prior to 4.6.62, src/praisonai/praisonai/tools/multiedit.py passes the LLM-controlled filepath parameter directly to open for reading and writing without traversal rejection, symlink resolution, a workspace boundary, or protected-path checks. Prompt-influenced agents can read files through edit and diff behavior or overwrite files accessible to the process, exposing secrets...
CVE-2026-61534 New	9.1	CRIT		0.008		Yayson is a library for serializing and reading JSON API data in JavaScript. Prior to 4.3.0, Store and LegacyStore use attacker-controlled JSON:API type, id, and relationship names as keys in plain-object lookup tables in src/yayson/store.ts and src/yayson/legacy-store.ts. A document whose type is __proto__ causes model-cache writes to modify Object.prototype, with the attacker controlling the polluted property na...
CVE-2026-68006 Newly scored	9.1	CRIT		0.004		An issue in Puma v.5.0.0 and before v.8.0.3 allows an attacker to execute arbitrary code via the ext/puma_http11/http11_parser.rl file
CVE-2026-71640 Newly scored	9.1	CRIT		0.004		An issue in ZJU-FAST-Lab EGO-Planner-v2 All versions up to commit 5c99a95880401e2599638d567abc0e240396cb42 allows unsafe vehicle motion via improper handling of expired trajectory data in the replanning pipeline

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-78299 New	9.1	CRIT		0.003		In Eclipse Embedded CDT versions 6.0 to 6.7 if the CMSIS-Pack archive extracts a compromised CMSIS pack the archive extraction can extract files to locations outside of the pack, allowing writing of arbitrary files to other locations on disk.
CVE-2026-82441 New	9.1	CRIT		0.004		Description A submitted topology carries two lists of blobstore keys, `dependency_jars` and `dependency_artifacts`, which the client fills in after uploading the corresponding blobs. Nimbus performed no validation of their contents on the submission path, yet acts on them in two places. During cleanup of a finished topology, Nimbus deletes the keys named in those lists, and the deletion is performed as the Nimbu...
CVE-2026-84625 New	9.1	CRIT		0.002		A permissions issue was addressed with additional sandbox restrictions. This issue is fixed in iOS 27 and iPadOS 27, macOS Golden Gate 27, visionOS 27, watchOS 27. An app may be able to fingerprint the user.
CVE-2026-86881 New	9.1	CRIT		0.001	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	A certificate validation issue was addressed with improved certificate validation. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. An attacker with a compromised intermediate certificate authority may be able to issue certificates with arbitrary extended key usages.
CVE-2026-87785 New	9.1	CRIT		0.005		Authentication bypass by spoofing vulnerability in Apache Syncope. When the configured JWKS settings for internal JWT authentication are disclosed (at least protocol and key), an attacker can spoof another user's privileges after completing a successful authentication and obtaining a valid JWT. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 through 4.0.7, from 4.1.0-M0 through 4...
CVE-2026-87802 New	9.1	CRIT		0.003		Improper verification of cryptographic signature vulnerability in Apache Syncope. When SRA is configured for OAuth 2.0 without JWKS set URI assigned, an attacker can forge arbitrary JWTs to impersonate any user identity and permissions, gaining full access to services proxied by SRA. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 through 4.0.7, from 4.1.0-M0 through 4.1.2. Us...
CVE-2026-88007 Newly scored	9.1	CRIT		0.003	traefik:traefik	Traefik is an open source HTTP reverse proxy and load balancer. From 2.11.0 until 2.11.57 and 3.7.13, the HTTP/3 endpoint ConnContext does not call service.AddTransportOnContext, so kerberosRoundTripper uses a shared backend transport instead of a transport dedicated to each frontend connection. With HTTP/3 enabled, a backend using connection-bound NTLM or Negotiate authentication, and backend keep-alive, an unr...
CVE-2026-88008 Newly scored	9.1	CRIT		0.003	traefik:traefik	Traefik is an open source HTTP reverse proxy and load balancer. From 2.11.26 until 2.11.57 and 3.7.13, Traefik forwards a client-supplied Connection header requesting Upgrade, the Upgrade: h2c token, and HTTP2-Settings to a shared backend. If the backend accepts h2c and returns 101 Switching Protocols, Traefik enters a raw tunnel and no longer applies routers, BasicAuth, ForwardAuth, IPAllowList, RateLimit, access...
CVE-2026-89532 Newly scored	9.1	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: svcrdma: Fix pcl_for_each_segment for empty chunks When a parsed chunk list contains a chunk whose ch_segcount is zero, pcl_for_each_segment computes its inclusive upper bound as &chunk->ch_segments[ch_segcount - 1]. ch_segcount is u32, so the subtraction wraps to 0xFFFFFFFF and the bound lands far past the ch_segments flex array. The loop body ...
CVE-2026-89634 Newly scored	9.1	CRIT		0.007		In the Linux kernel, the following vulnerability has been resolved: smb: client: fix ALIGN() overflow in symlink_data() error context loop The check added by commit 7d9a7f1f96cd ("smb/client: fix possible infinite loop and oob read in symlink_data()") compared the post-ALIGN length against the remaining buffer, but ALIGN() itself can overflow: for ErrorDataLength near UINT32_MAX (e.g. 0xFFFFFFFF9), ALIGN(x, 8) wr...
CVE-2026-89649 Newly scored	9.1	CRIT		0.007		In the Linux kernel, the following vulnerability has been resolved: ceph: bound xattr value length in __build_xattrs() __build_xattrs() decodes the MDS-supplied xattr blob one attribute at a time. For each attribute it reads a 32-bit name length, advances past the name bytes, reads a 32-bit value length, records the value pointer, and advances past the value bytes. The two length fields are read with ceph_decode...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89650 Newly scored	9.1	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: ceph: bound num_export_targets array for mds info v2/v3 ceph_mdsmmap_decode() in fs/ceph/mdsmmap.c reads num_export_targets from each per-mds info record and advances the decode cursor by num_export_targets * sizeof(u32) without first checking that many bytes remain. The only upper-bound check that catches a runaway cursor (*p > info_end) is gated...
CVE-2026-89671 Newly scored	9.1	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: nfsd: gate nfs3 setacl by argp->mask nfsd3_proc_setacl() calls set_posix_acl() unconditionally for both ACL_TYPE_ACCESS and ACL_TYPE_DEFAULT, passing argp->acl_access and argp->acl_default verbatim. The NFSv3 ACL decoder only populates those pointers when the corresponding mask bit is set: nfs3svc_decode_setaclargs() if (argp->mask & ...
CVE-2026-89672 Newly scored	9.1	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: nfsd: gate nfs2 setacl by argp->mask The NFSACL v2 SETACL path shares the decoder convention used by its v3 sibling: nfsaclsvc_decode_setaclargs() fills in argp->acl_access only when NFS_ACL is set in the request mask and argp->acl_default only when NFS_DFACL is set, leaving the other pointer NULL because the argument buffer is zeroed up to pc_a...
CVE-2026-89697 Newly scored	9.1	CRIT		0.007		In the Linux kernel, the following vulnerability has been resolved: nfsd: add fh_want_write() for early-verified SETATTR in nfsd_proc_setattr() The BOTH_TIME_SET branch calls fh_verify() early so setattr_prepare() can inspect the dentry. This causes nfsd_setattr() to skip fh_want_write(), so notify_change() runs without a mount write reference. Add the missing fh_want_write() call after the early fh_verify().

Watchlist matches (other priorities)

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-69461 Newly scored	8.8	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Stack-based buffer overflow in Windows NTFS allows an unauthorized attacker to execute code over a network.
CVE-2026-69518 Newly scored	8.8	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Remote Desktop allows an unauthorized attacker to execute code over a network.
CVE-2026-90938 New	8.8	HIGH		0.003		LangBot's plugin runtime (pip package langbot_plugin) through 0.4.17 starts a debug WebSocket server on 0.0.0.0:5401 (/plugin/ws) whose authentication is gated on plugin_debug_key, which defaults to an empty string and is never set by the upstream repository, Docker image, or docker-compose (which additionally publishes port 5401 to the host); the key check is therefore skipped entirely. Any remote attacker able t...
CVE-2026-82028 New	8.7	HIGH		0.004		Magistrala before 1.0.0 contains a SQL injection vulnerability in the timescale-reader and postgres-reader HTTP API services that allows authenticated attackers to inject arbitrary SQL by supplying a malicious format query parameter that is interpolated directly into the FROM clause without parameterization or identifier quoting. Attackers with a self-registered account can substitute arbitrary subqueries to achie...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-54628 New	8.6	HIGH		0.003		Anyquery is an SQL query engine built on top of SQLite. Prior to 0.4.5, anyquery server exposes URL-capable SQLite virtual table modules such as json_reader and log_reader through its unauthenticated MySQL-compatible server port without restricting outbound destinations. A remote attacker can provide a loopback, private-network, or link-local cloud metadata URL, causing go-getter in the Anyquery server process to ...
CVE-2026-57122 New	8.6	HIGH		0.001		PraisonAI is a multi-agent teams system. Prior to 4.6.59, the WhatsApp and Linear bot webhook handlers verify HMAC signatures only when WHATSAPP_APP_SECRET or LINEAR_WEBHOOK_SECRET is configured and otherwise parse and dispatch unsigned request bodies. A remote unauthenticated client that reaches the webhook route can forge messages, comments, or agent-session events, impersonate platform users, influence agent pr...
CVE-2026-69479 Newly scored	8.4	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows NTFS allows an unauthorized attacker to execute code locally.
CVE-2026-87958 Newly scored	8.1	HIGH		0.002	ibm:db2	IBM Db2 11.5.0 through 11.5.9, and 12.1.0 through 12.1.5 is vulnerable to a denial of service where a specific functionality on a Db2 server can be disabled by a privileged user under certain conditions.
CVE-2026-68834 Newly scored	8.0	HIGH		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Stack-based buffer overflow in Windows NTFS allows an authorized attacker to elevate privileges over a network.
CVE-2026-68838 Newly scored	8.0	HIGH		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Stack-based buffer overflow in Windows NTFS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69332 Newly scored	8.0	HIGH		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows NTFS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69505 Newly scored	8.0	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows NTFS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69826 Newly scored	8.0	HIGH		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges over a network.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-68832 Newly scored	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Integer overflow or wraparound in Windows NTFS allows an authorized attacker to elevate privileges locally.
CVE-2026-68841 Newly scored	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows NTFS allows an authorized attacker to elevate privileges locally.
CVE-2026-68875 Newly scored	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Buffer over-read in Windows NTFS allows an authorized attacker to execute code locally.
CVE-2026-69265 Newly scored	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows NTFS allows an authorized attacker to elevate privileges locally.
CVE-2026-69293 Newly scored	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69312 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows NTFS allows an authorized attacker to elevate privileges locally.
CVE-2026-69421 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Integer underflow (wrap or wraparound) in Windows Kernel Mode Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69475 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Untrusted pointer dereference in Windows Remote Desktop Services allows an authorized attacker to elevate privileges locally.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-69532 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows NTFS allows an authorized attacker to elevate privileges locally.
CVE-2026-69738 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Integer overflow or wraparound in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72991 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-82430 New	7.8	HIGH		0.001		Description When launching a Docker or OCI worker, the setuid-root `worker-launcher` first changes ownership of the entire worker directory to the untrusted topology user, and only afterwards reads and acts on the command file that the supervisor wrote into that same directory. The file is opened without `O_NOFOLLOW` and without re-verifying its owner, so between the ownership change and the read the tenant can r...
CVE-2026-47701 New	7.7	HIGH		0.003		The OpenTelemetry Operator is a Kubernetes Operator for the OpenTelemetry Collector. Prior to 0.152.0, cmd/otel-allocator TargetAllocator instances with targetAllocator.prometheusCR.enabled set to true preserve a selected ServiceMonitor endpoint's bearerTokenFile value as HTTPClientConfig.Authorization.CredentialsFile. A tenant who can create or update a ServiceMonitor matched by serviceMonitorSelector and service...
CVE-2026-55253 New	7.7	HIGH		0.004		LangChain MongoDB provides integrations between MongoDB, Atlas, LangChain, and LangGraph. Prior to langgraph-checkpoint-mongodb 0.3.0 and langgraph-store-mongodb 0.4.0, MongoDBSaver.list(), MongoDBSaver.alist(), and MongoDBStore.search() incorporate filter dictionaries into MongoDB queries without recursively rejecting keys prefixed with \$. An authenticated caller who controls a filter argument through HTTP query ...
CVE-2026-73496 New	7.7	HIGH		0.003		MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). Prior to 0.22.0, the confluence_upload_attachment and confluence_upload_attachments tools pass a client-controlled file_path through src/mcp_atlassian/confluence/attachments.py upload_attachment, and the jira_update_issue_attachments parameter reaches src/mcp_atlassian/jira/attachments.py upload_attachment, without...
CVE-2026-54629 New	7.5	HIGH		0.01		Anyquery is an SQL query engine built on top of SQLite. Prior to 0.4.5, anyquery server exposes file-backed SQLite virtual table modules such as csv_reader and log_reader through its MySQL-compatible server port without authentication, authorization, or directory restrictions. A remote attacker can use SQLite CREATE VIRTUAL TABLE statements to provide a local path to these modules, which use hashicorp/go-getter un...
CVE-2026-69514 Newly scored	7.5	HIGH		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Remote Desktop Services allows an authorized attacker to execute code over a network.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-69539 Newly scored	7.5	HIGH		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Remote Desktop Services allows an authorized attacker to execute code over a network.
CVE-2026-69599 Newly scored	7.5	HIGH		0.007	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:wi	Use after free in Windows Remote Desktop Services allows an authorized attacker to execute code over a network.
CVE-2026-76442 New	7.5	HIGH		0.004		As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Email Gateway and Cisco Secure Email and Web Manager engineering team has conducted a comprehensive internal security review. This review resulted in software hardening releases that address multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-76442 are related to issues with impr...
CVE-2026-86093 Newly scored	7.5	HIGH		0.005	ibm:db2	IBM Db2 11.5.0 through 11.5.9, and 12.1.0 through 12.1.5 could allow an attacker with the ability to control or impersonate a DRDA server endpoint to execute arbitrary commands on Db2 clients due to a stack-based buffer overflow that improperly copies user-controlled data into a fixed-size stack buffer without bounds checking.
CVE-2026-53714 New	7.4	HIGH		0.003		Envoy Gateway is an open source project for managing Envoy Proxy as a standalone or Kubernetes-based application gateway. Prior to 1.7.4 and 1.8.1, the xDS gRPC server in GatewayNamespaceMode, configured through provider.kubernetes.deploy.type=GatewayNamespace, installs a JWT StreamInterceptor but no UnaryInterceptor, leaving every unary Fetch RPC unauthenticated. The streaming interceptor also authenticates only ...
CVE-2024-58383 New	7.3	HIGH		0.001		Froxlор before 2.2.0 (affected up to and including 2.2.0-rc3) generates /etc/pure-ftpd/db/mysql.conf with mode 0644 via the XML configuration templates in lib/configfiles/, even though the file contains the Froxlор SQL user's password. On systems where the parent directories are world readable (the default on Debian 12), any unprivileged local user able to execute commands or code on the host — including virtual u...
CVE-2026-68893 Newly scored	7.1	HIGH		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Use after free in Windows Remote Desktop Licensing Service allows an authorized attacker to elevate privileges over a network.
CVE-2026-69340 Newly scored	7.1	HIGH		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows NTFS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69366 Newly scored	7.1	HIGH		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Kernel allows an authorized attacker to elevate privileges over a network.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-69536 Newly scored	7.1	HIGH		0.004	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:wi	Use after free in Windows Remote Desktop Services allows an authorized attacker to execute code over a network.
CVE-2026-82076 Newly scored	7.1	HIGH		0.003	mongodb:mongodb	An integer overflow in the query planning component of MongoDB Server can allow an authenticated user with ordinary database-level read/write privileges to bypass an internal resource limit. Submitting a specially crafted query causes the server to consume memory without bound during query planning, and the resulting exhaustion terminates the server process. This may result in a denial of service affecting all dat...
CVE-2026-91145 New	7.1	HIGH		0.002		Activiti through 7.1.0.M6 fails to validate hash-brace deferred expressions in process variables, allowing attackers to bypass expression filtering. Attackers can inject expressions beginning with #{ that are stored and later evaluated in the full Spring context when a mail task uses variable-backed body fields, enabling method invocation on application beans.
CVE-2026-68884 Newly scored	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Kernel allows an authorized attacker to elevate privileges locally.
CVE-2026-69287 Newly scored	7.0	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Remote Desktop Services allows an authorized attacker to elevate privileges locally.
CVE-2026-69379 Newly scored	7.0	HIGH		0.003	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:wi	Improper link resolution before file access ('link following') in Windows NTFS allows an authorized attacker to elevate privileges locally.
CVE-2026-69466 Newly scored	7.0	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Time-of-check time-of-use (toctou) race condition in Windows Kernel allows an authorized attacker to elevate privileges locally.
CVE-2026-69473 Newly scored	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Kernel allows an authorized attacker to elevate privileges locally.
CVE-2026-69501 Newly scored	7.0	HIGH		0.002	microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:wi	Untrusted pointer dereference in Windows Secure Kernel Mode allows an authorized attacker to elevate privileges locally.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-69567 Newly scored	7.0	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows NTFS allows an authorized attacker to elevate privileges locally.
CVE-2026-69578 Newly scored	7.0	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Numeric truncation error in Windows Kernel allows an authorized attacker to elevate privileges locally.
CVE-2026-50025 Newly scored	6.9	MEDI		0.002		Mousehole is a background service to update a seedbox IP for MAM and web app to manage it. Prior to version 0.4.05, Mousehole's HTTP/WebSocket management boundary is reachable without application-layer authentication or browser/LAN provenance checks. The service stores a MyAnonamouse (MAM) session cookie in state and reuses the same cookie-bearing serialization for persisted state, public API responses, and WebSoc...
CVE-2026-68833 Newly scored	6.8	MEDI		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows NTFS allows an unauthorized attacker to execute code with a physical attack.
CVE-2026-69566 Newly scored	6.8	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows NTFS allows an unauthorized attacker to execute code with a physical attack.
CVE-2026-53716 New	6.5	MEDI		0.007		Envoy Gateway is an open source project for managing Envoy Proxy as a standalone or Kubernetes-based application gateway. Prior to 1.7.4 and 1.8.1, getFileFromGZ in internal/wasm/httpfetcher.go calls io.ReadAll on a gzip.Reader without limiting decompressed output when a tenant-controlled EnvoyExtensionPolicy.spec.wasm[].code.http.url points to a reachable compressed Wasm payload. The 256 MiB compressed-input cap ...
CVE-2026-53717 New	6.5	MEDI		0.007		Envoy Gateway is an open source project for managing Envoy Proxy as a standalone or Kubernetes-based application gateway. Prior to 1.7.4 and 1.8.1, internal/wasm/imagefetcher.go follows tenant-controlled EnvoyExtensionPolicy spec.wasm[].code.image.url values to Docker or OCI Wasm layers, and extractWasmPluginBinary uses the untrusted tar-header h.Size value to allocate memory before validating the entry name or de...
CVE-2026-53719 New	6.5	MEDI		0.007		Envoy Gateway is an open source project for managing Envoy Proxy as a standalone or Kubernetes-based application gateway. Prior to 1.7.4 and 1.8.1, translateSecurityPolicyForRoute in internal/gatewayapi/securitypolicy.go dereferences a nil authorization value when a namespace-scoped tenant creates a SecurityPolicy targeting a TCPRoute and omits spec.authorization. The persistent object triggers the panic on every ...
CVE-2026-54248 Newly scored	6.5	MEDI		0.002		Doco-CD is a GitOps continuous delivery tool that automatically deploys and updates Docker Compose projects/services and Swarm stacks. Prior to version 0.90.1, a trust-boundary flaw in OCI artifact verification allowed artifact-provided deployment config to influence the policy used to verify that same artifact. When global OCI signature verification was enabled via `OCI_TRUST_POLICY` ('enabled: true'), an attacke...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-54723 New	6.5	MEDI		0.003		devpi is a Python package index staging server and packaging, testing, and release tool. Prior to 6.20.2 and 7.0.0b3, a server configured with the primary or deprecated master role allows an unauthenticated, modified GET request to the +changelog route because verify_primary does not reject a missing identity and therefore fails to require Replicadentity. The response can disclose complete database content, inclu...
CVE-2026-73497 New	6.5	MEDI		0.002		MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). From 0.17.0 until 0.22.0, validate_url_for_ssrf resolves the attacker-controlled X-Atlassian-Jira-Url and X-Atlassian-Confluence-Url header host once at middleware time, but the outbound request is built with the raw hostname and resolves it again at connection time with no IP pinning. An attacker-controlled DNS-re...
CVE-2026-53718 New	6.4	MEDI		0.003		Envoy Gateway is an open source project for managing Envoy Proxy as a standalone or Kubernetes-based application gateway. Prior to 1.7.4 and 1.8.1, an HTTPRoute can use an extension-managed custom backendRef to reference a backend resource in another namespace without a matching Gateway API ReferenceGrant in the target namespace. The custom-backend branch in internal/gatewayapi/route.go omits validateBackendNamesp...
CVE-2026-55102 New	5.8	MEDI		0.001		hashi-vault-js is a Node.js module for interacting with the HashiCorp Vault API. Prior to 0.5.2, every API method in src/Vault.js passes failed requests through parseAxiosError(), which rethrows the raw AxiosError while retaining AxiosError.config and the equivalent response configuration. These objects can contain the X-Vault-Token request header and err.config.data request body, including submitted passwords or ...
CVE-2026-54246 New	5.7	MEDI		0.003		Skipper is an HTTP router and reverse proxy for service composition. Prior to 0.27.13, the routesrv component serves cluster-wide control-plane data without application-layer authentication through /routes, /routes/{zone}, /swarm/redis/shards, and /swarm/valkey/shards. The handlers registered in routesrv/routesrv.go, eskipBytes.ServeHTTP in routesrv/eskipbytes.go, RedisHandler.ServeHTTP in routesrv/redishandler.go...
CVE-2026-69591 Newly scored	5.7	MEDI		0.009	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Out-of-bounds read in Windows NTFS allows an authorized attacker to disclose information over a network.
CVE-2026-68851 Newly scored	5.5	MEDI		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Buffer over-read in Windows NTFS allows an authorized attacker to disclose information locally.
CVE-2026-69406 Newly scored	5.5	MEDI		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Exposure of sensitive system information to an unauthorized control sphere in Windows Kernel allows an authorized attacker to disclose information locally.
CVE-2026-69504 Newly scored	5.5	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows NTFS allows an authorized attacker to disclose information locally.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-53715 New	5.3	MEDI		0.004		Envoy Gateway is an open source project for managing Envoy Proxy as a standalone or Kubernetes-based application gateway. Prior to 1.7.4 and 1.8.1, HTTPServer.ServeHTTP in internal/wasm/httpserver.go reads the plain mappingPath2Cache map without synchronization while HTTPServer.Get writes the same map during EnvoyExtensionPolicy translation. An attacker with pod-network access to unauthenticated port 18002 and ten...
CVE-2026-90935 New	5.3	MEDI		0.002		Froxlор before 2.3.7 fails to validate the mysql_server parameter against a customer's allowed_mysqlserver allowlist in the Mysqls.add API command. Attackers can supply a disallowed server index to create MySQL databases and users on forbidden servers, bypassing per-customer access controls.
CVE-2026-44913 Updated	5.2	MEDI		0.006	maven:org.apache.nifi:nifi-cdc-mysq l-processors fixed: 2.10.0	Improper escaping of database table names in the CaptureChangeMySQL Processor included with Apache NiFi 1.2.0 through 2.9.0 allows for injecting SQL commands using crafted naming. Manual quoted boundaries added in Apache NiFi 1.8.0 narrowed the scope of potential injection options, but did not cover additional strategies. Apache NiFi installations that do not use the CaptureChangeMySQL Processor are not subject to...
CVE-2026-54247 New	4.3	MEDI		0.002		Skipper is an HTTP router and reverse proxy for service composition. Prior to 0.26.22, Handler in dataclients/kubernetes/admission/admission.go passes the body of requests to the Kubernetes admission endpoint at :9443/admission directly to io.ReadAll(r.Body) without a size limit. An attacker with in-cluster network access and a valid Kubernetes client certificate can send a very large body that causes unbounded me...
CVE-2026-86087 Newly scored	4.3	MEDI		0.002	ibm:db2	IBM Db2 11.5.0 through 11.5.9, and 12.1.0 through 12.1.5 could allow an authenticated user to send a specially crafted request to write arbitrary files on the system.

P3/P4 items (1165) are in the Excel report. Unsourced CVEs are newly published and awaiting NVD analysis; re-check tomorrow's report.